

Normes et méthodes de sécurité

Cours de licence 3 — 40 heures

DISCOURS COMPLET DE L'ENSEIGNANT

10 modules de 4 h · Cours + travaux dirigés · Étude de cas fil rouge
Support aligné diapositive par diapositive sur normes_methodes_securite_40h.pptx

COMMENT UTILISER CE DOCUMENT

Ce document contient l'intégralité de ce que l'enseignant peut dire, diapositive par diapositive. Le texte courant correspond au discours à prononcer (reformulable avec ses propres mots). Les encadrés de couleur sont des repères pour l'enseignant ; ils ne se lisent pas à voix haute.

TRANSITION

annonce le passage d'une notion à la suivante.

CONSEIL D'ANIMATION

conseil d'animation ou de rythme.

INTERACTION — À FAIRE

moment d'échange ou d'activité avec les étudiants.

À RETENIR

message essentiel à faire retenir.

OBJECTIF

rappel de l'objectif d'apprentissage associé.

DÉFINITION

définition à poser clairement.

EXEMPLE

exemple concret pour ancrer la notion.

POINT DE VIGILANCE

piège fréquent ou point de vigilance.

Découpage horaire indicatif (40 heures)

Introduction	h 0 □ h 1
Module 1 — Fondamentaux de la sécurité	h 1 □ h 5
Module 2 — Gouvernance & cadre normatif	h 5 □ h 9
Module 3 — ISO/IEC 27001:2022 — le SMSI	h 9 □ h 13
Module 4 — ISO/IEC 27002:2022 — mesures	h 13 □ h 17
Module 5 — Gestion des risques	h 17 □ h 21
Module 6 — NIST CSF 2.0 & référentiels	h 21 □ h 25
Module 7 — Politiques & mesures	h 25 □ h 29
Module 8 — Audit, conformité & droit	h 29 □ h 33
Module 9 — SecOps, DevSecOps & Cloud	h 33 □ h 37
Module 10 — Étude de cas & examen	h 37 □ h 40

Les durées sont indicatives ; adapter selon le rythme du groupe et les exercices choisis.

INTRODUCTION

Diapositive 1 — Normes et méthodes de sécurité

Bonjour à toutes et à tous, et bienvenue dans ce cours intitulé « Normes et méthodes de sécurité ». Pendant quarante heures, nous allons apprendre à protéger un système d'information non pas au hasard, mais de façon organisée, méthodique et reconnue par des référentiels internationaux.

Ce cours ne demande aucun prérequis technique avancé. Nous allons construire ensemble, brique par brique, un vocabulaire commun, puis les grandes normes — la famille ISO 27000, le cadre du NIST — et enfin les méthodes concrètes comme la gestion des risques ou l'audit. L'objectif final : que vous sachiez comment une organisation sérieuse pilote sa sécurité.

CONSEIL D'ANIMATION

Prendre deux minutes pour se présenter, présenter le fil rouge du cours (une étude de cas suivie tout du long) et rassurer : on part de zéro, on avance progressivement, et chaque notion sera illustrée.

À RETENIR

Message d'ouverture : la sécurité de l'information est d'abord une affaire de méthode et de gouvernance, pas seulement de technique.

Diapositive 2 — De quoi parle ce cours ?

Commençons par clarifier le titre. Trois mots comptent : sécurité, normes, méthodes. La sécurité de l'information, c'est l'ensemble des moyens qui préservent trois propriétés de nos données : leur confidentialité, leur intégrité et leur disponibilité. Nous y reviendrons en détail dès le module 1.

Les normes sont des référentiels partagés : des documents, souvent internationaux, qui disent ce qu'il faut faire pour bien gérer la sécurité. Les méthodes, elles, disent comment le faire, étape par étape : comment analyser un risque, comment auditer, comment s'améliorer en continu.

DÉFINITION

Une norme décrit le « quoi » (les exigences, les bonnes pratiques) ; une méthode décrit le « comment » (la démarche pour y parvenir). Le cours articule sans cesse ces deux dimensions.

TRANSITION

Voyons maintenant ce que vous saurez faire à la fin de ces quarante heures.

Diapositive 3 — Objectifs pédagogiques

OBJECTIF

À l'issue du cours, vous devez être capables de tenir une conversation professionnelle sur la sécurité : comprendre un auditeur, lire une politique, participer à une analyse de risque.

Regardez ces objectifs comme une progression. On commence par le vocabulaire, indispensable pour se comprendre. Puis on situe les grandes normes, on entre dans le détail du SMSI — le système de management de la sécurité de l'information — et on apprend à analyser les risques.

Ensuite, on relie tout cela aux mesures concrètes et au cadre légal, de plus en plus présent avec des textes comme le RGPD ou la directive NIS2. Enfin, on met tout en pratique dans une étude de cas et on prépare un audit, comme dans la vraie vie professionnelle.

CONSEIL D'ANIMATION

Inviter les étudiants à noter, dès aujourd'hui, l'objectif qui leur parle le plus : cela crée un fil personnel de motivation.

Diapositive 4 — Le programme en 10 modules

Voici notre feuille de route : dix modules de quatre heures chacun. Les trois premiers posent les fondations et le système de management. Les modules 4 à 6 couvrent les mesures et les grands référentiels.

Les modules 7 à 9 descendent vers le concret : les politiques, les mesures techniques, l'audit, le droit, puis la sécurité opérationnelle et le cloud. Enfin, le module 10 est entièrement consacré à une étude de cas où vous jouerez le rôle d'une équipe sécurité qui construit le SMSI d'une PME.

TRANSITION

Un mot maintenant sur l'organisation pratique et l'évaluation.

Diapositive 5 — Organisation & évaluation

Quelques repères pratiques. Le cours fait quarante heures, découpées en dix modules de quatre heures. Chaque module mélange des apports théoriques, des exemples et au moins un exercice dirigé.

L'évaluation combine trois choses : le contrôle continu à travers les exercices, un projet qui est l'étude de cas fil rouge, et un examen final écrit. Autrement dit, si vous suivez les exercices au fur et à mesure, vous préparez déjà votre examen.

CONSEIL D'ANIMATION

Adapter ce tableau aux modalités réelles de l'établissement : coefficients, dates, éventuel oral de soutenance du projet.

TRANSITION

Nous avons le cadre. Entrons dans le vif du sujet avec les fondamentaux.

MODULE 01 — FONDAMENTAUX DE LA SÉCURITÉ DE L'INFORMATION · Concepts, vocabulaire et principes directeurs

Diapositive 6 — Fondamentaux de la sécurité de l'information

Nous ouvrons le premier module, consacré aux fondamentaux. C'est la brique sur laquelle tout le reste va s'appuyer. Sans ce vocabulaire commun, les normes et les méthodes resteraient abstraites.

OBJECTIF

À la fin de ce module, vous saurez définir la sécurité de l'information, distinguer menace, vulnérabilité et risque, et citer les grands principes de protection.

Diapositive 7 — Objectifs du module 1

Voici précisément ce que nous visons dans ce module. Cinq capacités, très concrètes, qui vont revenir en permanence dans la suite du cours. Prenez-les comme une grille de lecture.

CONSEIL D'ANIMATION

Annoncer qu'un exercice de synthèse clôturera le module pour vérifier ces objectifs.

Diapositive 8 — Qu'est-ce que la sécurité de l'information ?

Posons la première définition. La sécurité de l'information, c'est protéger l'information sous toutes ses formes. Et j'insiste : toutes ses formes. Un document papier confidentiel oublié sur une imprimante, une conversation dans un train, un fichier sur un serveur : ce sont trois problèmes de sécurité de l'information.

DÉFINITION

Sécurité de l'information : préservation de la confidentialité, de l'intégrité et de la disponibilité de l'information, quelle que soit sa forme.

On confond souvent trois termes. La cybersécurité concerne le cyberspace et les systèmes numériques. La sécurité des systèmes d'information, ou SSI, concerne les SI d'une organisation. Et la sécurité de l'information englobe tout cela, y compris le non numérique. Retenez l'emboîtement : l'information est le concept le plus large.

POINT DE VIGILANCE

Erreur fréquente chez les étudiants : réduire la sécurité à l'informatique. Un post-it avec un mot de passe est déjà une faille de sécurité de l'information.

Diapositive 9 — Les critères DICP

Voici le cœur du réacteur : les critères de sécurité. Dans le monde anglo-saxon, on parle de la triade CIA — Confidentiality, Integrity, Availability. En France, l'ANSSI ajoute un quatrième critère, la preuve, ce qui donne l'acronyme DICP.

DÉFINITION

Disponibilité : pouvoir accéder à l'information au bon moment. Intégrité : garantir qu'elle n'a pas été modifiée indûment. Confidentialité : réserver l'accès aux personnes autorisées. Preuve : pouvoir tracer et prouver les actions.

EXEMPLE

Un hôpital : la disponibilité du dossier patient peut sauver une vie ; l'intégrité d'une prescription évite une erreur de dose ; la confidentialité protège la vie privée ; la traçabilité permet de savoir qui a consulté quoi.

À RETENIR

Toute mesure de sécurité vise à protéger au moins un de ces critères. Se demander « quel critère je protège ? » est un réflexe d'expert.

Diapositive 10 — Actif, valeur métier, bien support

Avant de protéger, il faut savoir quoi protéger. On parle d'actifs, ou de biens. Un actif, c'est tout ce qui a de la valeur : une donnée, un logiciel, un équipement, mais aussi une personne ou une réputation.

DÉFINITION

La méthode française EBIOS distingue la valeur métier — l'information ou le processus essentiel à la mission — et le bien support — le serveur, le logiciel, la personne ou le local sur lequel repose cette valeur métier.

EXEMPLE

Pour une école : la valeur métier, ce sont les notes des étudiants ; les biens supports, ce sont le logiciel de scolarité, le serveur qui l'héberge, et l'agent qui le gère.

À RETENIR

On ne peut pas protéger ce que l'on n'a pas recensé. La cartographie des actifs est la toute première étape, et souvent la plus négligée.

Diapositive 11 — Menace, vulnérabilité, risque

Voici quatre mots que l'on mélange tout le temps, et qu'il faut absolument distinguer. Une menace, c'est un danger potentiel : un attaquant, mais aussi une panne, une erreur humaine, un incendie. Une vulnérabilité, c'est une faiblesse : une faille logicielle, l'absence de sauvegarde, une porte non verrouillée.

DÉFINITION

Le risque naît de la rencontre entre une menace et une vulnérabilité : c'est un scénario probable, associé à un impact — les conséquences si le scénario se réalise.

EXEMPLE

La pluie est une menace. Un trou dans le toit est une vulnérabilité. Le risque, c'est « la pluie entre par le trou ». L'impact, c'est le parquet abîmé. Réparer le toit supprime la vulnérabilité ; on ne peut pas empêcher la pluie.

À RETENIR

On agit rarement sur la menace (on ne contrôle pas les attaquants) ; on agit surtout sur les vulnérabilités et sur l'impact. C'est toute la logique des mesures de sécurité.

Diapositive 12 — Qui sont les sources de menace ?

Les menaces ne sont pas toutes des pirates encapuchonnés. Distinguons les sources. Les cybercriminels, d'abord, motivés par l'argent : c'est la grande majorité. Les États et l'espionnage industriel, plus rares mais très sophistiqués. Les hacktivistes, qui défendent une cause.

Mais n'oubliez jamais les menaces internes et accidentelles : le salarié mécontent, et surtout l'erreur humaine, qui est l'une des premières causes d'incident. Enfin, les pannes et catastrophes — un incendie de datacenter menace la disponibilité tout autant qu'un attaquant.

POINT DE VIGILANCE

Ne pas se focaliser uniquement sur l'attaquant externe. Beaucoup d'incidents majeurs viennent d'erreurs internes ou de pannes.

Diapositive 13 — Surface d'attaque & défense en profondeur

Deux notions structurantes. D'abord la surface d'attaque : c'est l'ensemble des points par lesquels quelqu'un pourrait entrer. Chaque service exposé sur Internet, chaque compte, chaque logiciel installé agrandit cette surface. Réduire la surface d'attaque — fermer ce qui est inutile — est un réflexe de base.

DÉFINITION

Défense en profondeur : ne jamais compter sur une seule barrière, mais empiler plusieurs lignes de défense indépendantes, pour que la défaillance de l'une soit rattrapée par la suivante.

EXEMPLE

Le château fort : les douves, puis la muraille, puis le donjon. En informatique : le pare-feu, puis l'authentification, puis le chiffrement des données, puis les sauvegardes.

À RETENIR

Réduire la surface d'attaque et multiplier les couches de protection : deux réflexes que l'on retrouvera dans toutes les normes.

Diapositive 14 — Les grands principes de sécurité

Terminons les concepts par les grands principes, les règles d'or que tout professionnel connaît. Le moindre privilège : chacun ne reçoit que les droits strictement nécessaires à son travail, ni plus. Le besoin d'en connaître : on n'accède à une information que si on en a réellement besoin.

La sécurité par conception, ou security by design : on ne rajoute pas la sécurité à la fin, on la pense dès le départ. La séparation des tâches : aucune personne seule ne doit pouvoir mener une action sensible de bout en bout, pour éviter la fraude. Et le Zero Trust, très en vogue : ne jamais faire confiance par défaut, toujours vérifier, même à l'intérieur du réseau.

À RETENIR

Ces principes ne sont pas théoriques : on les retrouvera, presque mot pour mot, dans les mesures des normes ISO 27002 et du NIST.

Diapositive 15 — ≈ 80 %

Je veux insister sur un point avant de clore les concepts : l'humain. On cite souvent que la grande majorité des incidents impliquent, à un moment ou à un autre, un facteur humain — une erreur, une négligence, ou une manipulation par ingénierie sociale. Prenez ce chiffre comme un ordre de grandeur, pas comme une mesure exacte.

La conséquence est fondamentale pour tout notre cours : la sécurité ne peut pas être seulement technique. Elle est aussi une affaire d'organisation, de règles, de sensibilisation et de culture. C'est exactement pour cela que les normes insistent autant sur la gouvernance et sur les personnes.

À RETENIR

La meilleure technologie ne protège pas une organisation où personne n'est sensibilisé ni responsabilisé.

Diapositive 16 — Exercice — Cartographier un risque

INTERACTION — À FAIRE

Constituer les binômes, laisser 20 minutes de travail puis 10 minutes de restitution. Circuler pour aider à distinguer valeur métier et bien support, confusion la plus fréquente.

À vous de jouer. L'objectif n'est pas d'être exhaustif, mais de manipuler le vocabulaire : valeur métier, bien support, critère DICP, menace, vulnérabilité, risque. Choisissez une organisation simple que vous connaissez, et déroulez la chaîne.

CONSEIL D'ANIMATION

Faire ressortir, lors de la restitution, qu'un même actif peut relever de plusieurs critères DICP, et que les binômes formulent souvent une vulnérabilité comme une menace : corriger ensemble.

Diapositive 17 — L'essentiel du module 1

Récapitulons ce premier module. La sécurité de l'information protège quatre critères : disponibilité, intégrité, confidentialité et preuve. Elle s'applique à des actifs, qu'il faut d'abord recenser.

Le risque naît d'une menace qui exploite une vulnérabilité, avec un impact à la clé. On s'en protège par des principes — moindre privilège, défense en profondeur — et en gardant à l'esprit que l'humain est central. Ce vocabulaire va nous servir dans tout le reste du cours.

TRANSITION

Maintenant que nous partageons un langage commun, montons d'un cran : qui organise la sécurité, et avec quels référentiels ? C'est l'objet du module 2, la gouvernance et le cadre normatif.

MODULE 02 — GOUVERNANCE ET CADRE NORMATIF · Pourquoi les organisations ont besoin de règles, de rôles et de référentiels

Diapositive 18 — Gouvernance et cadre normatif

Nous ouvrons le module 2 : Gouvernance et cadre normatif. Ce module représente environ quatre heures de cours et de travaux dirigés.

OBJECTIF

Le but est de transformer les notions du module en décisions concrètes : quoi documenter, quoi justifier, quoi vérifier.

Diapositive 19 — Objectifs du module 2

Présenter les objectifs comme une feuille de route. Les étudiants doivent comprendre que chaque objectif correspond à une compétence réutilisable dans l'étude de cas fil rouge.

- Expliquer pourquoi la sécurité doit être gouvernée par la direction
- Distinguer norme, standard, règlement, guide et référentiel
- Identifier les principaux organismes de référence
- Situer la famille ISO/IEC 27000 dans un programme de sécurité
- Comprendre le cycle d'amélioration continue PDCA

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 20 — Pourquoi gouverner la sécurité ?

Cette diapositive sert à installer la notion « Pourquoi gouverner la sécurité ? ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- La sécurité est un risque d'entreprise : financier, juridique, opérationnel et d'image
- Elle nécessite des arbitrages : budget, priorités, acceptation du risque
- La direction fixe l'appétence au risque et les responsabilités
- Les équipes techniques appliquent une stratégie, elles ne la remplacent pas

EXEMPLE

Une équipe IT peut proposer d'acheter un EDR ; seule la direction peut arbitrer le budget, le périmètre et le risque résiduel accepté.

À RETENIR

La gouvernance transforme la sécurité d'un ensemble d'outils en système de décisions maîtrisées.

Diapositive 21 — Norme, standard, règlement, référentiel

Cette diapositive sert à installer la notion « Norme, standard, règlement, référentiel ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Norme » Document reconnu, souvent international, issu d'un organisme de normalisation
- Standard » Pratique largement adoptée, parfois industrielle ou communautaire
- Règlement / loi » Obligation juridique contraignante : non-respect = sanctions
- Guide » Recommandations opérationnelles, souvent non obligatoires
- Référentiel » Ensemble structuré d'exigences, contrôles ou critères d'évaluation

DÉFINITION

Une norme peut être volontaire, mais devenir obligatoire par contrat, règlement sectoriel ou exigence client.

POINT DE VIGILANCE

Ne pas confondre conformité à une norme et sécurité absolue : une organisation certifiée reste exposée aux risques.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 22 — Les organismes à connaître

Cette diapositive sert à installer la notion « Les organismes à connaître ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- ISO/IEC : Normes internationales, dont la famille 27000
- NIST : Référentiels américains très utilisés : CSF, SP 800
- ANSSI : Autorité nationale française en cybersécurité
- CNIL : Protection des données personnelles et RGPD
- ENISA : Agence européenne de cybersécurité
- CIS / OWASP : Bonnes pratiques opérationnelles et applicatives

À RETENIR

Un professionnel ne connaît pas toutes les normes par cœur ; il sait où chercher la bonne référence.

Diapositive 23 — La famille ISO/IEC 27000

Cette diapositive sert à installer la notion « La famille ISO/IEC 27000 ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- ISO/IEC 27000 : Vocabulaire et vue d'ensemble des SMSI
- ISO/IEC 27001 : Exigences certifiables du SMSI
- ISO/IEC 27002 : Mesures de sécurité et guide de bonnes pratiques
- ISO/IEC 27005 : Gestion des risques de sécurité de l'information
- ISO/IEC 27017 / 27018 : Sécurité cloud et données personnelles dans le cloud
- ISO/IEC 27701 : Extension management de la vie privée

À RETENIR

27001 dit ce qui est exigé ; 27002 aide à choisir et mettre en œuvre les mesures.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 24 — Exigences vs mesures de sécurité

Cette diapositive sert à installer la notion « Exigences vs mesures de sécurité ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

Faire comparer les deux colonnes : la première montre un point de vue, la seconde montre le complément ou la bonne pratique attendue. L'intérêt est de faire verbaliser les différences, pas seulement de les lire.

- Côté gauche : Ce qui doit être démontré, Souvent formulé en « l'organisation doit... », Vérifiable lors d'un audit, Exemple : réaliser des audits internes planifiés
- Côté droit : Ce qui traite concrètement un risque, Peut être organisationnel, humain, physique ou technique, Doit être justifié par l'analyse de risque, Exemple : MFA, sauvegardes, classification

À RETENIR

Un audit vérifie des exigences ; un plan de sécurité met en œuvre des mesures.

Diapositive 25 — Le cycle PDCA

Cette diapositive sert à installer la notion « Le cycle PDCA ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Plan : Comprendre le contexte, fixer objectifs, évaluer les risques
- Étape 2 — Do : Mettre en œuvre politiques, processus et mesures
- Étape 3 — Check : Mesurer, auditer, analyser les incidents et indicateurs

- Étape 4 — Act : Corriger, améliorer, réviser le plan et les priorités

EXEMPLE

Une campagne de sensibilisation n'est pas terminée quand elle est diffusée : on mesure les résultats, on corrige le contenu et on recommence.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 26 — Rôles de gouvernance SSI

Cette diapositive sert à installer la notion « Rôles de gouvernance SSI ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Direction » Fixe l'appétence au risque, approuve les moyens et arbitre
- RSSI / CISO » Anime la stratégie, conseille, coordonne et rend compte
- DSI » Met en œuvre les moyens techniques et l'exploitation
- Métiers » Expriment les besoins, possèdent les risques métier
- Juridique / DPO » Traite obligations contractuelles, RGPD et preuves
- Auditeur » Évalue objectivement la conformité et l'efficacité

À RETENIR

Un risque appartient au métier qui porte l'activité, pas uniquement à l'IT.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 27 — La documentation : preuve et mémoire

Cette diapositive sert à installer la notion « La documentation : preuve et mémoire ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Politique de sécurité : intention et engagements de haut niveau
- Procédures : comment réaliser une activité de façon répétable
- Enregistrements : preuves qu'une activité a bien été faite
- Versioning, approbation, diffusion et revue périodique sont essentiels
- Sans preuve, l'auditeur considère souvent que l'action n'est pas démontrée

POINT DE VIGILANCE

Documenter ne veut pas dire produire du papier inutile : chaque document doit soutenir une décision, une pratique ou une preuve.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 28 — TD — Cartographier l'écosystème normatif

Cette diapositive sert à installer la notion « TD — Cartographier l'écosystème normatif ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

INTERACTION — À FAIRE

Lancer l'activité en reformulant la consigne, puis laisser les étudiants produire avant de corriger. L'enseignant circule pour repérer les confusions.

- Lister 5 parties prenantes : clients, régulateurs, fournisseurs, direction, utilisateurs
- Associer à chacune au moins une attente de sécurité
- Choisir les référentiels pertinents : ISO 27001, RGPD, guide ANSSI, NIST CSF, CIS
- Justifier ce qui relève de l'obligation, de la bonne pratique ou de l'exigence contractuelle

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 29 — L'essentiel du module 2

Cette diapositive clôt le module. L'enseignant la lit lentement et relie chaque phrase à un exemple vu pendant les quatre heures.

À RETENIR

La gouvernance donne un cadre aux décisions de sécurité. Les normes et référentiels ne remplacent pas le jugement : ils structurent les responsabilités, les preuves et l'amélioration continue.

TRANSITION

On peut maintenant passer au module suivant, qui réutilisera ce socle dans un contexte plus appliqué.

MODULE 03 — ISO/IEC 27001:2022 — CONSTRUIRE UN SMSI

• Le système de management de la sécurité de l'information, ses clauses et son audit

Diapositive 30 — ISO/IEC 27001:2022 — construire un SMSI

Nous ouvrons le module 3 : ISO/IEC 27001:2022 — construire un SMSI. Ce module représente environ quatre heures de cours et de travaux dirigés.

OBJECTIF

Le but est de transformer les notions du module en décisions concrètes : quoi documenter, quoi justifier, quoi vérifier.

Diapositive 31 — Objectifs du module 3

Présenter les objectifs comme une feuille de route. Les étudiants doivent comprendre que chaque objectif correspond à une compétence réutilisable dans l'étude de cas fil rouge.

- Définir ce qu'est un SMSI et ce qu'il n'est pas
- Expliquer les clauses 4 à 10 d'ISO/IEC 27001:2022
- Rédiger les éléments clés d'un périmètre SMSI
- Comprendre le rôle central de la déclaration d'applicabilité
- Décrire le cycle de certification et de surveillance

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 32 — Un SMSI, ce n'est pas un logiciel

Cette diapositive sert à installer la notion « Un SMSI, ce n'est pas un logiciel ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- SMSI = système de management de la sécurité de l'information
- Ensemble coordonné : politiques, processus, rôles, mesures, preuves
- Objectif : gérer durablement les risques liés à l'information
- Il s'intègre aux processus de l'organisation et s'améliore en continu

DÉFINITION

Un SMSI est un système de pilotage. Il organise les décisions de sécurité, leur mise en œuvre, leur contrôle et leur amélioration.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 33 — Les clauses 4 à 10

Cette diapositive sert à installer la notion « Les clauses 4 à 10 ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- 4 · Contexte » Qui sommes-nous, quelles attentes, quel périmètre ?
- 5 · Leadership » Qui porte la sécurité et avec quelle politique ?
- 6 · Planification » Quels risques, objectifs et plans de traitement ?
- 7 · Support » Quelles ressources, compétences, communications, preuves ?
- 8 · Opération » Comment exécute-t-on les processus du SMSI ?
- 9 · Évaluation » Comment mesure-t-on, audite-t-on, révise-t-on ?
- 10 · Amélioration » Comment corriger et améliorer en continu ?

À RETENIR

Ces clauses sont les exigences certifiables : l'auditeur les vérifie systématiquement.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 34 — Définir le périmètre du SMSI

Cette diapositive sert à installer la notion « Définir le périmètre du SMSI ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Inclure : entités, sites, processus, systèmes, données, interfaces
- Justifier les exclusions : elles doivent être cohérentes et défendables
- Identifier les parties intéressées et leurs exigences
- Relier le périmètre aux risques et aux objectifs métier

EXEMPLE

Une startup SaaS peut définir un SMSI limité à la plateforme cloud de production et aux processus support, sans inclure tous les postes personnels hors périmètre.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 35 — Leadership : engagements attendus

Cette diapositive sert à installer la notion « Leadership : engagements attendus ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

Faire comparer les deux colonnes : la première montre un point de vue, la seconde montre le complément ou la bonne pratique attendue. L'intérêt est de faire verbaliser les différences, pas seulement de les lire.

- Côté gauche : Une politique approuvée par la direction, Des responsabilités attribuées et connues, Des ressources effectivement allouées, Des preuves de revues et décisions
- Côté droit : Politique copiée-collée non connue, RSSI isolé sans pouvoir d'arbitrage, Objectifs sécurité non suivis, Aucune trace de décision de direction

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 36 — Planification : risques » objectifs

Cette diapositive sert à installer la notion « Planification : risques » objectifs ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Critères de risque : Définir échelles, seuils d'acceptation et responsabilités
- Étape 2 — Appréciation : Identifier, analyser et évaluer les risques
- Étape 3 — Traitement : Choisir mesures, acceptation, transfert ou évitement
- Étape 4 — Objectifs : Fixer des objectifs mesurables et un plan pour les atteindre

À RETENIR

La clause 6 relie directement analyse de risque, choix des mesures et objectifs du SMSI.

Diapositive 37 — Support : faire vivre le système

Cette diapositive sert à installer la notion « Support : faire vivre le système ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Ressources : Budget, outils, temps, responsabilités
- Compétence : Former les personnes selon leurs rôles
- Sensibilisation : Faire comprendre la politique et les impacts
- Communication : Qui communique quoi, quand, à qui ?
- Information documentée : Créer, mettre à jour, maîtriser les preuves
- Traçabilité : Démontrer que le SMSI fonctionne réellement

À RETENIR

Le SMSI ne vit pas dans un classeur : il vit dans les habitudes et les preuves.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 38 — Opération, évaluation, amélioration

Cette diapositive sert à installer la notion « Opération, évaluation, amélioration ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Opérer : Exécuter les processus : risques, traitements, contrôles
- Étape 2 — Mesurer : Suivre indicateurs, incidents, écarts, efficacité
- Étape 3 — Auditer : Vérifier objectivement conformité et fonctionnement
- Étape 4 — Revoir : La direction arbitre sur la base des résultats
- Étape 5 — Corriger : Traiter non-conformités et améliorer le SMSI

EXEMPLE

Une non-conformité n'est pas un échec : c'est une opportunité de rendre le système plus robuste.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 39 — La déclaration d'applicabilité (SoA)

Cette diapositive sert à installer la notion « La déclaration d'applicabilité (SoA) ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Mesures nécessaires » Montre ce que l'organisation a choisi de mettre en place
- Justification d'inclusion » Relie chaque mesure au risque ou à l'exigence
- Statut de mise en œuvre » Indique ce qui est fait, partiel ou prévu
- Justification d'exclusion » Explique pourquoi une mesure Annex A n'est pas retenue
- Lien au plan de traitement » Fait le pont entre risques, décisions et actions

POINT DE VIGILANCE

Une SoA générique sans lien au registre des risques est une faiblesse majeure en audit.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 40 — Le cycle de certification

Cette diapositive sert à installer la notion « Le cycle de certification ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Préparation : Gap analysis, preuves, audit interne, revue de direction
- Étape 2 — Stage 1 : Revue documentaire : le SMSI est-il prêt ?
- Étape 3 — Stage 2 : Audit de mise en œuvre : le SMSI fonctionne-t-il ?
- Étape 4 — Surveillance : Audits annuels partiels pendant le cycle
- Étape 5 — Recertification : Audit complet tous les trois ans

À RETENIR

La certification prouve un système maîtrisé à un instant donné ; elle n'élimine pas les risques.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 41 — TD — Définir un périmètre SMSI

Cette diapositive sert à installer la notion « TD — Définir un périmètre SMSI ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

INTERACTION — À FAIRE

Lancer l'activité en reformulant la consigne, puis laisser les étudiants produire avant de corriger. L'enseignant circule pour repérer les confusions.

- Décrire l'activité, les clients et les informations sensibles
- Inclure/exclure sites, équipes, systèmes et processus
- Identifier 5 parties intéressées et leurs attentes
- Rédiger une phrase de périmètre en langage audit

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 42 — L'essentiel du module 3

Cette diapositive clôt le module. L'enseignant la lit lentement et relie chaque phrase à un exemple vu pendant les quatre heures.

À RETENIR

ISO/IEC 27001:2022 structure le SMSI autour d'un cycle de management : contexte, leadership, planification, support, opération, évaluation et amélioration. Le périmètre, le registre de risques et la SoA en sont les pièces maîtresses.

TRANSITION

On peut maintenant passer au module suivant, qui réutilisera ce socle dans un contexte plus appliqué.

MODULE 04 — ISO/IEC 27002:2022 — CHOISIR ET APPLIQUER LES MESURES · Comprendre les 93 mesures de sécurité, leurs thèmes et leur sélection par le risque

Diapositive 43 — ISO/IEC 27002:2022 — choisir et appliquer les mesures

Nous ouvrons le module 4 : ISO/IEC 27002:2022 — choisir et appliquer les mesures. Ce module représente environ quatre heures de cours et de travaux dirigés.

OBJECTIF

Le but est de transformer les notions du module en décisions concrètes : quoi documenter, quoi justifier, quoi vérifier.

Diapositive 44 — Objectifs du module 4

Présenter les objectifs comme une feuille de route. Les étudiants doivent comprendre que chaque objectif correspond à une compétence réutilisable dans l'étude de cas fil rouge.

- Différencier ISO/IEC 27001 et ISO/IEC 27002
- Présenter les 4 thèmes et 93 mesures de l'édition 2022
- Classer les mesures selon leur type et leur objectif
- Choisir des mesures à partir d'un risque identifié
- Documenter l'applicabilité et les preuves attendues

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 45 — ISO 27001 vs ISO 27002

Cette diapositive sert à installer la notion « ISO 27001 vs ISO 27002 ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

Faire comparer les deux colonnes : la première montre un point de vue, la seconde montre le complément ou la bonne pratique attendue. L'intérêt est de faire verbaliser les différences, pas seulement de les lire.

- Côté gauche : Standard d'exigences certifiable, Définit le SMSI et ses clauses, Demande d'identifier et traiter les risques, Annex A sert de référence de mesures
- Côté droit : Guide de bonnes pratiques, Explique les mesures de sécurité, Aide à les sélectionner et les mettre en œuvre, Non certifiable directement

À RETENIR

27001 pose les exigences ; 27002 éclaire le choix et l'application des contrôles.

Diapositive 46 — ISO/IEC 27002:2022 en chiffres

Cette diapositive sert à installer la notion « ISO/IEC 27002:2022 en chiffres ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- 93 mesures : Référence Annex A alignée ISO 27001:2022
- 4 thèmes : Organisationnel, personnes, physique, technologique
- 11 nouvelles mesures : Cloud, threat intelligence, secure coding, DLP...
- Attributs : Vues par type, propriétés DICP, concepts cyber, capacités

À RETENIR

L'édition 2022 simplifie la structure : 114 contrôles/14 domaines en 2013 » 93 mesures/4 thèmes.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 47 — Thème 1 — Mesures organisationnelles

Cette diapositive sert à installer la notion « Thème 1 — Mesures organisationnelles ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Politiques : Règles et responsabilités de sécurité
- Gestion des actifs : Inventaire, classification, usage acceptable
- Fournisseurs : Contrats, exigences, surveillance, supply chain
- Cloud : Sécurité de l'utilisation des services cloud
- Incidents : Préparation, décision, réponse, preuve, retour d'expérience
- Conformité : Lois, propriété intellectuelle, données personnelles

À RETENIR

Le plus grand thème est organisationnel : la norme rappelle que la sécurité est d'abord pilotée.

Diapositive 48 — Thème 2 — Personnes

Cette diapositive sert à installer la notion « Thème 2 — Personnes ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Avant l'emploi : Screening proportionné, conditions d'emploi
- Pendant l'emploi : Sensibilisation, formation, processus disciplinaire
- Changement / départ : Responsabilités après terminaison ou changement
- Télétravail & signalement : Règles hors site et canal de remontée d'événements

EXEMPLE

Un départ collaborateur doit déclencher restitution des actifs, révocation des accès et rappel des engagements de confidentialité.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 49 — Thème 3 — Physique

Cette diapositive sert à installer la notion « Thème 3 — Physique ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Périmètres : Zones, badges, visiteurs, salles sensibles
- Surveillance : Détection intrusion, vidéo, journal visiteurs
- Environnement : Feu, eau, énergie, climatisation, protections
- Équipements : Positionnement, maintenance, effacement, destruction

POINT DE VIGILANCE

Le cloud ne supprime pas le physique : il le transfère partiellement au fournisseur, à vérifier contractuellement.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 50 — Thème 4 — Technologique

Cette diapositive sert à installer la notion « Thème 4 — Technologique ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Identités & accès : Authentification, privilèges, restriction
- Postes & malware : Terminaux, anti-malware, filtrage web
- Vulnérabilités : Patch, configuration, durcissement
- Données : Chiffrement, masquage, suppression, DLP
- Réseau & logs : Segmentation, services réseau, journalisation
- Développement : Cycle de vie sécurisé, exigences, test, code sûr

À RETENIR

Les mesures techniques ne se choisissent pas seules : elles doivent répondre à un risque ou une exigence.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 51 — Les 11 nouvelles mesures de l'édition 2022

Cette diapositive sert à installer la notion « Les 11 nouvelles mesures de l'édition 2022 ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- A.5.7 Threat intelligence » Mieux intégrer la connaissance de la menace
- A.5.23 Cloud services » Clarifier la responsabilité partagée du cloud
- A.5.30 ICT readiness » Relier sécurité et continuité d'activité
- A.7.4 Physical monitoring » Surveiller les accès physiques
- A.8.9 Configuration » Maîtriser les configurations et dérives
- A.8.10 Information deletion » Supprimer correctement les données
- A.8.11 Data masking » Limiter l'exposition des données sensibles
- A.8.12 DLP » Réduire les fuites d'information
- A.8.16 Monitoring » Détecter les comportements anormaux
- A.8.23 Web filtering » Réduire les accès web dangereux
- A.8.28 Secure coding » Prévenir les vulnérabilités applicatives

À RETENIR

Ces nouveautés reflètent l'évolution du cloud, du développement logiciel et de la menace.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 52 — Attributs des mesures

Cette diapositive sert à installer la notion « Attributs des mesures ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Type » Préventif, détectif, correctif
- Propriétés sécurité » Confidentialité, intégrité, disponibilité
- Concept cyber » Identifier, protéger, détecter, répondre, rétablir
- Capacité opérationnelle » IAM, gouvernance, sécurité applicative, continuité...
- Domaine de sécurité » Gouvernance, protection, défense, résilience

EXEMPLE

Une mesure de journalisation est détective, soutient la preuve et sert surtout la détection/réponse.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 53 — Sélectionner une mesure par le risque

Cette diapositive sert à installer la notion « Sélectionner une mesure par le risque ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Scénario : Formuler un risque clair : menace + vulnérabilité + impact
- Étape 2 — Besoin : Identifier le critère DICP à protéger
- Étape 3 — Options : Comparer mesures possibles : coût, efficacité, faisabilité
- Étape 4 — Choix : Documenter inclusion/exclusion dans la SoA
- Étape 5 — Preuve : Définir comment l'efficacité sera démontrée

À RETENIR

Un contrôle est fort quand il est justifié, implémenté, prouvé et revu.

Diapositive 54 — TD — Choisir des contrôles ISO 27002

Cette diapositive sert à installer la notion « TD — Choisir des contrôles ISO 27002 ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

INTERACTION — À FAIRE

Lancer l'activité en reformulant la consigne, puis laisser les étudiants produire avant de corriger. L'enseignant circule pour repérer les confusions.

- Formuler le risque et le critère DICP principal
- Choisir 6 mesures : au moins une organisationnelle, une humaine et une technique
- Justifier chaque mesure par rapport au risque
- Indiquer une preuve d'audit attendue pour chaque mesure

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 55 — L'essentiel du module 4

Cette diapositive clôt le module. L'enseignant la lit lentement et relie chaque phrase à un exemple vu pendant les quatre heures.

À RETENIR

ISO/IEC 27002:2022 est une boîte à outils de 93 mesures. On ne les applique pas mécaniquement : on les sélectionne selon les risques, les exigences et les preuves attendues.

TRANSITION

On peut maintenant passer au module suivant, qui réutilisera ce socle dans un contexte plus appliqué.

MODULE 05 — MÉTHODES DE GESTION DES RISQUES · ISO 27005 et EBIOS Risk Manager v1.5 : de l'analyse au plan de traitement

Diapositive 56 — Méthodes de gestion des risques

Nous ouvrons le module 5 : Méthodes de gestion des risques. Ce module représente environ quatre heures de cours et de travaux dirigés.

OBJECTIF

Le but est de transformer les notions du module en décisions concrètes : quoi documenter, quoi justifier, quoi vérifier.

Diapositive 57 — Objectifs du module 5

Présenter les objectifs comme une feuille de route. Les étudiants doivent comprendre que chaque objectif correspond à une compétence réutilisable dans l'étude de cas fil rouge.

- Construire un vocabulaire solide du risque
- Décrire le cycle ISO 27005 aligné avec ISO 31000
- Évaluer impact et vraisemblance avec des critères explicites
- Dérouler les 5 ateliers EBIOS Risk Manager v1.5
- Produire un registre de risques et un plan de traitement

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 58 — Cycle de gestion du risque

Cette diapositive sert à installer la notion « Cycle de gestion du risque ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Contexte : Périmètre, critères, parties prenantes, objectifs
- Étape 2 — Appréciation : Identifier, analyser, évaluer les risques
- Étape 3 — Traitement : Modifier, éviter, transférer ou accepter le risque
- Étape 4 — Communication : Partager décisions et responsabilités
- Étape 5 — Surveillance : Réviser selon incidents, changements et indicateurs

À RETENIR

Le risque est dynamique : une analyse non mise à jour devient rapidement fausse.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 59 — Définir les critères de risque

Cette diapositive sert à installer la notion « Définir les critères de risque ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Échelle d'impact » Quels niveaux : mineur, significatif, majeur, critique ?
- Échelle de vraisemblance » Sur quoi se fonde-t-on : exposition, menace, maturité ?
- Seuil d'acceptation » À partir de quel niveau faut-il traiter ?
- Propriétaires » Qui décide d'accepter un risque résiduel ?
- Catégories d'impact » Financier, juridique, image, opérationnel, humain

POINT DE VIGILANCE

Changer les critères en cours d'analyse pour obtenir un résultat souhaité détruit la crédibilité de la démarche.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 60 — Identifier les risques

Cette diapositive sert à installer la notion « Identifier les risques ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Partir des valeurs métier et biens supports
- Associer sources de menace, vulnérabilités et événements redoutés
- Formuler le risque comme un scénario compréhensible
- Éviter les formulations vagues : « cyberattaque » n'est pas un risque assez précis
- Documenter hypothèses et sources utilisées

EXEMPLE

« Un attaquant obtient un compte administrateur via phishing et exfiltre la base clients » est plus utile que « piratage du SI ».

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 61 — Analyser : impact × vraisemblance

Cette diapositive sert à installer la notion « Analyser : impact × vraisemblance ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Impact » Conséquences sur DICP, finance, juridique, image, continuité
- Vraisemblance » Exposition, facilité d'exploitation, niveau de menace, contrôles existants
- Risque initial » Niveau avant mesures additionnelles
- Risque résiduel » Niveau après traitement prévu
- Priorité » Décision : traiter maintenant, surveiller, accepter

À RETENIR

Une matrice de risque n'est qu'un outil de décision : elle ne remplace pas l'argumentation.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 62 — Options de traitement

Cette diapositive sert à installer la notion « Options de traitement ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Modifier / réduire : Mettre en place des mesures pour diminuer impact ou vraisemblance
- Éviter : Arrêter ou changer l'activité trop risquée
- Partager / transférer : Assurance, contrat, externalisation partielle
- Accepter : Assumer le risque résiduel à un niveau autorisé

POINT DE VIGILANCE

Transférer n'efface pas le risque : l'organisation reste responsable vis-à-vis de ses clients et régulateurs.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 63 — EBIOS Risk Manager v1.5 : vue d'ensemble

Cette diapositive sert à installer la notion « EBIOS Risk Manager v1.5 : vue d'ensemble ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Atelier 1 : Cadrage et socle de sécurité
- Étape 2 — Atelier 2 : Sources de risque et objectifs visés
- Étape 3 — Atelier 3 : Scénarios stratégiques dans l'écosystème
- Étape 4 — Atelier 4 : Scénarios opérationnels techniques

- Étape 5 — Atelier 5 : Traitement du risque et suivi

À RETENIR

La version 1.5 publiée par l'ANSSI en 2024 est alignée avec ISO 27005:2022.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 64 — Atelier 1 — Cadrage et socle

Cette diapositive sert à installer la notion « Atelier 1 — Cadrage et socle ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Définir l'objet de l'étude et le cadre temporel
- Identifier missions, valeurs métier et biens supports
- Identifier les événements redoutés et leur gravité
- Évaluer les écarts au socle de sécurité existant

À RETENIR

Si le périmètre est flou, toute l'analyse de risque sera floue.

Diapositive 65 — Atelier 2 — Sources de risque

Cette diapositive sert à installer la notion « Atelier 2 — Sources de risque ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Identifier qui pourrait attaquer ou nuire
- Associer chaque source à un objectif visé
- Évaluer motivation, ressources et activité
- Retenir les couples source de risque / objectif visé pertinents

EXEMPLE

Source : cybercriminels ; objectif : obtenir une rançon ; cible : disponibilité du service client.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 66 — Atelier 3 — Scénarios stratégiques

Cette diapositive sert à installer la notion « Atelier 3 — Scénarios stratégiques ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Cartographier l'écosystème : fournisseurs, partenaires, clients, prestataires
- Évaluer la dangerosité des parties prenantes
- Construire des chemins d'attaque de haut niveau
- Associer les scénarios aux événements redoutés et à la gravité

À RETENIR

Les attaques passent souvent par l'écosystème : fournisseur, compte prestataire, API tierce.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 67 — Atelier 4 — Scénarios opérationnels

Cette diapositive sert à installer la notion « Atelier 4 — Scénarios opérationnels ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Traduire les chemins stratégiques en modes opératoires techniques
- Identifier les actions élémentaires sur biens supports
- Évaluer la vraisemblance de chaque scénario opérationnel
- Produire une synthèse des scénarios de risque

EXEMPLE

Phishing d'un administrateur » vol de jeton MFA » accès VPN » extraction base clients.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 68 — Atelier 5 — Traitement et suivi

Cette diapositive sert à installer la notion « Atelier 5 — Traitement et suivi ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Synthèse : Classer les risques selon leur niveau
- Étape 2 — Stratégie : Décider traitement, acceptation ou évitement
- Étape 3 — Mesures : Définir actions, responsables, échéances
- Étape 4 — Résiduel : Évaluer et faire accepter le risque restant
- Étape 5 — Suivi : Mettre à jour selon incidents, changements et menaces

À RETENIR

Le livrable important n'est pas seulement la matrice : c'est le plan de traitement suivi dans le temps.

Diapositive 69 — TD — Construire un scénario EBIOS

Cette diapositive sert à installer la notion « TD — Construire un scénario EBIOS ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

INTERACTION — À FAIRE

Lancer l'activité en reformulant la consigne, puis laisser les étudiants produire avant de corriger. L'enseignant circule pour repérer les confusions.

- Identifier 2 valeurs métier et 2 événements redoutés
- Choisir 1 source de risque et 1 objectif visé
- Décrire un scénario stratégique via un fournisseur ou utilisateur
- Décrire un scénario opérationnel en 4 actions élémentaires
- Proposer 4 mesures de traitement

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 70 — L'essentiel du module 5

Cette diapositive clôt le module. L'enseignant la lit lentement et relie chaque phrase à un exemple vu pendant les quatre heures.

À RETENIR

La gestion des risques transforme une peur générale en scénarios discutables, prioritaires et traitables. ISO 27005 donne le cadre ; EBIOS RM fournit une méthode concrète par ateliers.

TRANSITION

On peut maintenant passer au module suivant, qui réutilisera ce socle dans un contexte plus appliqué.

MODULE 06 — NIST CSF 2.0 ET AUTRES RÉFÉRENTIELS · Comparer, cartographier et utiliser plusieurs cadres de sécurité sans se perdre

Diapositive 71 — NIST CSF 2.0 et autres référentiels

Nous ouvrons le module 6 : NIST CSF 2.0 et autres référentiels. Ce module représente environ quatre heures de cours et de travaux dirigés.

OBJECTIF

Le but est de transformer les notions du module en décisions concrètes : quoi documenter, quoi justifier, quoi vérifier.

Diapositive 72 — Objectifs du module 6

Présenter les objectifs comme une feuille de route. Les étudiants doivent comprendre que chaque objectif correspond à une compétence réutilisable dans l'étude de cas fil rouge.

- Présenter les composants du NIST Cybersecurity Framework 2.0
- Expliquer les 6 fonctions : Govern, Identify, Protect, Detect, Respond, Recover
- Utiliser les profils current/target pour prioriser
- Situer CIS Controls, OWASP, COBIT, PCI DSS et SOC 2
- Construire une cartographie entre référentiels

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 73 — NIST CSF 2.0 : les composants

Cette diapositive sert à installer la notion « NIST CSF 2.0 : les composants ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Core : Taxonomie d'objectifs de cybersécurité
- Profils : État courant et état cible adaptés à l'organisation
- Tiers : Maturité de gouvernance et gestion du risque

À RETENIR

CSF 2.0 est volontaire et non prescriptif : il décrit des résultats attendus, pas une check-list unique.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 74 — Les 6 fonctions du NIST CSF 2.0

Cette diapositive sert à installer la notion « Les 6 fonctions du NIST CSF 2.0 ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Govern : Stratégie, rôles, politiques, supply chain
- Identify : Actifs, risques, améliorations, contexte
- Protect : Accès, formation, données, plateformes
- Detect : Surveillance et détection d'événements
- Respond : Gestion et communication d'incident
- Recover : Rétablissement et amélioration

À RETENIR

La fonction Govern a été ajoutée dans CSF 2.0 pour rendre visible la gouvernance.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 75 — Créer un profil CSF

Cette diapositive sert à installer la notion « Créer un profil CSF ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Scope : Définir l'activité ou le périmètre évalué
- Étape 2 — Current profile : Décrire l'état actuel face aux outcomes CSF
- Étape 3 — Target profile : Définir l'état cible selon risques et obligations
- Étape 4 — Gap : Identifier écarts et priorités
- Étape 5 — Roadmap : Planifier les actions et mesurer les progrès

EXEMPLE

Une PME peut viser un Target Profile plus ambitieux sur Respond/Recover si elle dépend fortement de sa plateforme en ligne.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 76 — Tiers CSF : maturité de gestion du risque

Cette diapositive sert à installer la notion « Tiers CSF : maturité de gestion du risque ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- 1 · Partial » Pratiques ad hoc, peu formalisées
- 2 · Risk informed » Risques connus mais approche pas toujours répétable
- 3 · Repeatable » Processus formalisés, gouvernance établie
- 4 · Adaptive » Amélioration continue, anticipation et adaptation

À RETENIR

Les Tiers ne sont pas une note de performance ; ils aident à choisir un niveau adapté au contexte.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 77 — Mapping ISO 27001 ↔ NIST CSF

Cette diapositive sert à installer la notion « Mapping ISO 27001 ↔ NIST CSF ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Gouvernance » ISO clauses 4-6 ↔ CSF Govern
- Inventaire actifs » ISO A.5.9 ↔ CSF Identify
- Accès » ISO A.5.15/A.8.2 ↔ CSF Protect
- Logs » ISO A.8.15/A.8.16 ↔ CSF Detect
- Incident » ISO A.5.24-5.28 ↔ CSF Respond
- Continuité » ISO A.5.29/A.5.30 ↔ CSF Recover

À RETENIR

Le mapping évite les doublons et permet de parler à plusieurs parties prenantes avec leur référentiel.

Diapositive 78 — CIS Controls

Cette diapositive sert à installer la notion « CIS Controls ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Priorisé : Mesures concrètes classées pour démarrer vite
- Technique : Inventaire, configuration, vulnérabilités, logs
- Groupes IG : Implementation Groups adaptés à la maturité
- Complément ISO : Très utile pour opérationnaliser les exigences

EXEMPLE

Une petite structure peut commencer par les contrôles CIS d'inventaire et de configuration avant de viser une certification ISO.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 79 — OWASP, SAMM, ASVS

Cette diapositive sert à installer la notion « OWASP, SAMM, ASVS ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- OWASP Top 10 : Risques applicatifs les plus courants
- ASVS : Exigences de vérification applicative
- SAMM : Modèle de maturité du développement sécurisé

À RETENIR

Pour les applications, ISO 27002 donne le cadre ; OWASP donne le détail opérationnel.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 80 — COBIT, ITIL, PCI DSS, SOC 2

Cette diapositive sert à installer la notion « COBIT, ITIL, PCI DSS, SOC 2 ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- COBIT : Gouvernance et management de l'IT
- ITIL : Gestion des services IT et processus opérationnels
- PCI DSS : Exigences pour les données de cartes de paiement
- SOC 2 : Rapport d'assurance sur contrôles de service (Trust Services Criteria)

POINT DE VIGILANCE

Chaque cadre a son objectif : les mélanger sans comprendre leur périmètre produit une conformité confuse.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 81 — Méthode pour ne pas se perdre

Cette diapositive sert à installer la notion « Méthode pour ne pas se perdre ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Périmètre : Quel service, données, organisation ?
- Étape 2 — Obligatoire : Quelles lois ou exigences client s'imposent ?
- Étape 3 — Référence principale : Choisir le cadre de pilotage : souvent ISO ou NIST
- Étape 4 — Mappings : Relier les autres cadres aux contrôles existants
- Étape 5 — Preuves communes : Mutualiser preuves, audits et indicateurs

À RETENIR

Une bonne GRC réduit les doublons : un contrôle bien documenté peut répondre à plusieurs exigences.

Diapositive 82 — TD — Construire un profil NIST CSF simplifié

Cette diapositive sert à installer la notion « TD — Construire un profil NIST CSF simplifié ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

INTERACTION — À FAIRE

Lancer l'activité en reformulant la consigne, puis laisser les étudiants produire avant de corriger. L'enseignant circule pour repérer les confusions.

- Choisir 8 outcomes répartis sur Govern, Protect, Detect, Respond
- Décrire l'état actuel en une phrase par outcome
- Définir l'état cible et le Tier souhaité
- Prioriser 5 actions de progression

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 83 — L'essentiel du module 6

Cette diapositive clôt le module. L'enseignant la lit lentement et relie chaque phrase à un exemple vu pendant les quatre heures.

À RETENIR

Le NIST CSF 2.0 aide à communiquer et prioriser. ISO structure le SMSI, CIS et OWASP opérationnalisent, COBIT/ITIL gouvernent l'IT : l'enjeu est de cartographier plutôt que d'empiler.

TRANSITION

On peut maintenant passer au module suivant, qui réutilisera ce socle dans un contexte plus appliqué.

MODULE 07 — POLITIQUES DE SÉCURITÉ ET MESURES CONCRÈTES · Passer des référentiels aux règles applicables dans l'organisation

Diapositive 84 — Politiques de sécurité et mesures concrètes

Nous ouvrons le module 7 : Politiques de sécurité et mesures concrètes. Ce module représente environ quatre heures de cours et de travaux dirigés.

OBJECTIF

Le but est de transformer les notions du module en décisions concrètes : quoi documenter, quoi justifier, quoi vérifier.

Diapositive 85 — Objectifs du module 7

Présenter les objectifs comme une feuille de route. Les étudiants doivent comprendre que chaque objectif correspond à une compétence réutilisable dans l'étude de cas fil rouge.

- Structurer une politique de sécurité et ses documents associés
- Définir les règles essentielles d'accès, d'identité et de privilèges
- Relier classification de l'information et mesures de protection
- Comprendre les exigences de chiffrement, logs, vulnérabilités et fournisseurs
- Produire une procédure simple et audit-able

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 86 — Hiérarchie documentaire sécurité

Cette diapositive sert à installer la notion « Hiérarchie documentaire sécurité ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Politique : Engagements de haut niveau approuvés par la direction
- Étape 2 — Standards : Règles obligatoires par domaine : mots de passe, cloud, logs
- Étape 3 — Procédures : Modes opératoires répétables : créer un compte, traiter un incident
- Étape 4 — Guides : Aide pratique et recommandations pour les utilisateurs
- Étape 5 — Enregistrements : Preuves : tickets, journaux, revues, attestations

À RETENIR

Plus on descend dans la hiérarchie, plus le document doit être concret et vérifiable.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 87 — IAM : gérer les identités et accès

Cette diapositive sert à installer la notion « IAM : gérer les identités et accès ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Joiner : Créer l'identité et les droits à l'arrivée
- Mover : Modifier les droits lors d'un changement de poste
- Leaver : Révoquer immédiatement au départ
- MFA : Ajouter un facteur d'authentification
- PAM : Contrôler les comptes à privilèges
- Revue : Vérifier régulièrement les droits

À RETENIR

L'IAM est souvent la mesure la plus structurante : elle réduit les abus, les erreurs et les compromissions.

Diapositive 88 — Moindre privilège vs privilèges permanents

Cette diapositive sert à installer la notion « Moindre privilège vs privilèges permanents ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

Faire comparer les deux colonnes : la première montre un point de vue, la seconde montre le complément ou la bonne pratique attendue. L'intérêt est de faire verbaliser les différences, pas seulement de les lire.

- Côté gauche : Comptes admin utilisés au quotidien, Droits jamais retirés après mutation, Comptes partagés sans traçabilité, Prestataires avec accès trop larges
- Côté droit : Droits just-in-time ou limités, Revue périodique par le métier, Comptes nominatifs et journaux, Accès prestataire bornés et surveillés

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 89 — Classification de l'information

Cette diapositive sert à installer la notion « Classification de l'information ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Public : Diffusion sans dommage significatif

- Interne : Usage réservé à l'organisation
- Confidentiel : Impact fort en cas de divulgation
- Secret / très sensible : Accès très restreint, mesures renforcées

EXEMPLE

Un support de cours public, une liste d'étudiants interne, un dossier médical confidentiel, une clé de chiffrement secrète.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 90 — Cryptographie : objectifs et limites

Cette diapositive sert à installer la notion « Cryptographie : objectifs et limites ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Chiffrement en transit : protéger les échanges (TLS, VPN)
- Chiffrement au repos : protéger fichiers, disques, bases
- Gestion des clés : création, stockage, rotation, révocation
- Signature : garantir origine et intégrité
- La cryptographie ne corrige pas une mauvaise gestion des accès

POINT DE VIGILANCE

Le vrai problème est souvent la gestion des clés, pas l'algorithme.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 91 — Journalisation et supervision

Cette diapositive sert à installer la notion « Journalisation et supervision ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Logs d'authentification, administration, accès aux données sensibles
- Horodatage fiable et synchronisation des systèmes
- Protection des journaux contre modification et suppression
- Analyse : alertes, corrélation, tableaux de bord
- Conservation proportionnée aux obligations et risques

À RETENIR

Sans logs, on ne sait ni détecter, ni enquêter, ni prouver.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 92 — Gestion des vulnérabilités

Cette diapositive sert à installer la notion « Gestion des vulnérabilités ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Inventorier : Savoir quels actifs et versions existent
- Étape 2 — Scanner : Identifier vulnérabilités et mauvaises configurations
- Étape 3 — Prioriser : Selon criticité, exposition, exploitabilité, métier
- Étape 4 — Corriger : Patch, configuration, mitigation ou exception formelle
- Étape 5 — Vérifier : Contrôler que la correction est effective

EXEMPLE

Un CVSS critique sur un serveur non exposé peut être moins urgent qu'un CVSS élevé exploité activement sur Internet.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 93 — Sécurité fournisseurs

Cette diapositive sert à installer la notion « Sécurité fournisseurs ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Avant contrat : Évaluer criticité, données, accès, maturité
- Contrat : Clauses sécurité, audit, incident, sous-traitance
- Pendant service : Suivi, revues, changements, indicateurs
- Fin de contrat : Réversibilité, restitution, suppression des données

À RETENIR

Un fournisseur critique devient une extension du système d'information.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 94 — Sensibilisation : changer les comportements

Cette diapositive sert à installer la notion « Sensibilisation : changer les comportements ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Former selon les rôles : utilisateurs, développeurs, administrateurs, direction
- Répéter régulièrement plutôt qu'une session unique annuelle
- Utiliser des exemples réalistes : phishing, données, télétravail
- Mesurer : taux de clic, signalements, quiz, incidents évités
- Valoriser les signalements plutôt que punir l'erreur de bonne foi

À RETENIR

Une culture de sécurité se construit par répétition, simplicité et confiance.

Diapositive 95 — TD — Rédiger une procédure audit-able

Cette diapositive sert à installer la notion « TD — Rédiger une procédure audit-able ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

INTERACTION — À FAIRE

Lancer l'activité en reformulant la consigne, puis laisser les étudiants produire avant de corriger. L'enseignant circule pour repérer les confusions.

- Définir objectif, périmètre, rôles et responsabilités
- Lister les étapes joiner/mover/leaver
- Indiquer les preuves à conserver
- Ajouter un contrôle périodique de revue des droits

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 96 — L'essentiel du module 7

Cette diapositive clôt le module. L'enseignant la lit lentement et relie chaque phrase à un exemple vu pendant les quatre heures.

À RETENIR

Les politiques transforment les normes en règles locales. Une bonne règle est comprise, applicable, reliée à un risque et vérifiable par des preuves.

TRANSITION

On peut maintenant passer au module suivant, qui réutilisera ce socle dans un contexte plus appliqué.

MODULE 08 — AUDIT, CONFORMITÉ ET CADRE JURIDIQUE · Prouver, vérifier et respecter les obligations de sécurité

Diapositive 97 — Audit, conformité et cadre juridique

Nous ouvrons le module 8 : Audit, conformité et cadre juridique. Ce module représente environ quatre heures de cours et de travaux dirigés.

OBJECTIF

Le but est de transformer les notions du module en décisions concrètes : quoi documenter, quoi justifier, quoi vérifier.

Diapositive 98 — Objectifs du module 8

Présenter les objectifs comme une feuille de route. Les étudiants doivent comprendre que chaque objectif correspond à une compétence réutilisable dans l'étude de cas fil rouge.

- Expliquer le déroulement d'un audit de sécurité ou de certification
- Identifier les types de preuves attendues
- Distinguer non-conformité, observation et opportunité d'amélioration
- Résumer les exigences clés RGPD, NIS2 et DORA
- Construire une approche de conformité intégrée

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 99 — Déroulement d'un audit

Cette diapositive sert à installer la notion « Déroulement d'un audit ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Planifier : Objectif, périmètre, critères, programme
- Étape 2 — Préparer : Demander documents, échantillons, interlocuteurs
- Étape 3 — Collecter : Entretiens, preuves, observations, tests
- Étape 4 — Conclure : Constats, non-conformités, niveau de confiance
- Étape 5 — Suivre : Plan d'action et vérification de clôture

À RETENIR

Un audit n'est pas une chasse au coupable : c'est une évaluation objective.

Diapositive 100 — Types de preuves d'audit

Cette diapositive sert à installer la notion « Types de preuves d'audit ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Documentaire » Politique, procédure, SoA, registre de risques
- Enregistrement » Ticket, log, compte rendu de revue, rapport de test
- Entretien » Explication cohérente par un responsable ou opérateur
- Observation » Constat direct d'une configuration ou pratique
- Échantillon » Vérification sur quelques cas représentatifs

À RETENIR

La meilleure preuve combine document, pratique observée et enregistrement.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 101 — Non-conformité majeure vs mineure

Cette diapositive sert à installer la notion « Non-conformité majeure vs mineure ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

Faire comparer les deux colonnes : la première montre un point de vue, la seconde montre le complément ou la bonne pratique attendue. L'intérêt est de faire verbaliser les différences, pas seulement de les lire.

- Côté gauche : Exigence absente ou non maîtrisée, Risque important non traité, Répétition d'écarts similaires, Peut bloquer une certification
- Côté droit : Écart ponctuel ou partiel, Processus existant mais perfectible, Amélioration recommandée, Plan d'action suivi requis

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 102 — Réussir un entretien d'audit

Cette diapositive sert à installer la notion « Réussir un entretien d'audit ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Répondre factuellement, sans inventer
- Montrer les preuves plutôt que promettre
- Dire « je vérifie » si l'information manque
- Relier la pratique au risque et à la procédure
- Ne pas cacher un écart : expliquer le plan de correction

POINT DE VIGILANCE

Une incohérence entre discours et preuve pèse plus lourd qu'un simple oubli.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 103 — RGPD : principes clés

Cette diapositive sert à installer la notion « RGPD : principes clés ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Licéité : Base légale et information des personnes
- Minimisation : Collecter seulement le nécessaire
- Exactitude : Données à jour et rectifiables
- Durée limitée : Conserver selon une durée justifiée
- Sécurité : Mesures techniques et organisationnelles appropriées
- Droits : Accès, rectification, effacement, opposition...

À RETENIR

Le RGPD demande une sécurité proportionnée au risque pour les personnes.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 104 — RGPD : sécurité et responsabilité

Cette diapositive sert à installer la notion « RGPD : sécurité et responsabilité ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Registre » Documenter les traitements et finalités
- DPIA / AIPD » Analyser les risques élevés pour les personnes
- Violation » Notifier si risque pour les droits et libertés
- Sous-traitants » Contrats, instructions, sécurité, assistance
- Privacy by design » Intégrer la protection dès la conception

EXEMPLE

Un projet biométrique ou de données santé nécessite souvent une AIPD avant mise en production.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 105 — NIS2 : logique générale

Cette diapositive sert à installer la notion « NIS2 : logique générale ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Champ élargi : 18 secteurs critiques ou importants
- Mesures de risque : Politiques, incident, continuité, supply chain, MFA...
- Notification : Incidents significatifs selon calendrier national
- Responsabilité : Management impliqué, supervision renforcée

À RETENIR

NIS2 est une directive : chaque État membre la transpose dans son droit national.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 106 — DORA : résilience numérique financière

Cette diapositive sert à installer la notion « DORA : résilience numérique financière ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- ICT risk management : Cadre complet de gestion des risques ICT
- Incident reporting : Classification et notification des incidents majeurs
- Testing : Tests de résilience, dont TLPT pour certains acteurs
- Third-party risk : Exigences contractuelles et supervision des prestataires ICT critiques

À RETENIR

DORA est un règlement directement applicable au secteur financier depuis janvier 2025.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 107 — Conformité intégrée

Cette diapositive sert à installer la notion « Conformité intégrée ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Inventaire obligations : Lois, contrats, normes, exigences clients
- Étape 2 — Mapping contrôles : Relier exigences à des contrôles communs

- Étape 3 — Preuves mutualisées : Un même ticket ou rapport sert plusieurs exigences
- Étape 4 — Calendrier : Audits, revues, renouvellements, notifications
- Étape 5 — Pilotage : Tableau de bord conformité et risques résiduels

À RETENIR

Une conformité efficace réutilise les mêmes contrôles et preuves au lieu de créer un dossier séparé par référentiel.

Diapositive 108 — TD — Préparer une checklist d'audit

Cette diapositive sert à installer la notion « TD — Préparer une checklist d'audit ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

INTERACTION — À FAIRE

Lancer l'activité en reformulant la consigne, puis laisser les étudiants produire avant de corriger. L'enseignant circule pour repérer les confusions.

- Définir 6 critères d'audit
- Associer une preuve attendue à chaque critère
- Prévoir 3 questions d'entretien
- Classer les constats possibles : majeur, mineur, observation

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 109 — L'essentiel du module 8

Cette diapositive clôt le module. L'enseignant la lit lentement et relie chaque phrase à un exemple vu pendant les quatre heures.

À RETENIR

L'audit transforme les promesses en preuves. Le droit impose des obligations, mais un SMSI bien construit permet de répondre à plusieurs cadres avec des contrôles communs.

TRANSITION

On peut maintenant passer au module suivant, qui réutilisera ce socle dans un contexte plus appliqué.

MODULE 09 — SÉCURITÉ OPÉRATIONNELLE, DEVSECOPS, CLOUD ET RÉSILIENCE · Faire fonctionner la sécurité au quotidien et préparer l'organisation aux incidents

Diapositive 110 — Sécurité opérationnelle, DevSecOps, Cloud et résilience

Nous ouvrons le module 9 : Sécurité opérationnelle, DevSecOps, Cloud et résilience. Ce module représente environ quatre heures de cours et de travaux dirigés.

OBJECTIF

Le but est de transformer les notions du module en décisions concrètes : quoi documenter, quoi justifier, quoi vérifier.

Diapositive 111 — Objectifs du module 9

Présenter les objectifs comme une feuille de route. Les étudiants doivent comprendre que chaque objectif correspond à une compétence réutilisable dans l'étude de cas fil rouge.

- Décrire les fonctions de sécurité opérationnelle et de SOC
- Construire un cycle simple de réponse à incident
- Intégrer la sécurité dans le développement logiciel
- Expliquer la responsabilité partagée du cloud
- Définir RTO, RPO, PCA, PRA et indicateurs de pilotage

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 112 — SecOps : sécurité au quotidien

Cette diapositive sert à installer la notion « SecOps : sécurité au quotidien ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Surveiller : SIEM, EDR, alertes, journaux
- Vulnérabilités : Scans, patch, priorisation
- Identités : Revues, MFA, PAM, anomalies
- Incidents : Triage, escalade, containment
- Threat intel : Veille menace et exploitation active
- Reporting : Indicateurs et amélioration continue

À RETENIR

SecOps est le bras opérationnel de la gouvernance sécurité.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 113 — Réponse à incident

Cette diapositive sert à installer la notion « Réponse à incident ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Préparer : Rôles, playbooks, outils, contacts, exercices
- Étape 2 — Détecter : Qualifier l'alerte et préserver les preuves
- Étape 3 — Contenir : Limiter la propagation et l'impact
- Étape 4 — Éradiquer : Supprimer cause racine, comptes, malware, faille
- Étape 5 — Rétablir : Restaurer service et surveiller le retour à la normale
- Étape 6 — Apprendre : REX, corrections, mise à jour des risques

À RETENIR

Pendant une crise, on applique une procédure préparée ; on n'improvise pas toute la méthode.

Diapositive 114 — Playbook d'incident : contenu minimal

Cette diapositive sert à installer la notion « Playbook d'incident : contenu minimal ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Déclenchement » Quels signaux ? Qui peut déclarer l'incident ?
- Rôles » Incident manager, technique, communication, juridique, DPO
- Actions » Isoler, préserver preuve, changer secrets, restaurer
- Communication » Interne, client, autorités, presse
- Clôture » Critères de retour à la normale et REX

EXEMPLE

Un playbook ransomware doit inclure : isolation réseau, gel des sauvegardes, communication, décision juridique et restauration.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 115 — DevSecOps : intégrer la sécurité au pipeline

Cette diapositive sert à installer la notion « DevSecOps : intégrer la sécurité au pipeline ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Plan : Exigences sécurité et threat modeling
- Étape 2 — Code : Guides de codage, secrets, revue
- Étape 3 — Build : SAST, dépendances, SBOM, signature
- Étape 4 — Test : DAST, tests d'abus, scans conteneurs
- Étape 5 — Deploy : IaC sécurisé, approbations, segmentation
- Étape 6 — Run : Logs, monitoring, correction continue

À RETENIR

DevSecOps ne veut pas dire ralentir : il automatise les contrôles pour détecter tôt.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 116 — OWASP Top 10 : familles de risques applicatifs

Cette diapositive sert à installer la notion « OWASP Top 10 : familles de risques applicatifs ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Contrôle d'accès cassé : Droits mal appliqués côté serveur
- Cryptographie défaillante : Données mal protégées
- Injection : SQL, commandes, expressions
- Mauvaise configuration : Services, headers, cloud, debug
- Composants vulnérables : Dépendances obsolètes ou compromises
- Identification/auth : Sessions, mots de passe, MFA

À RETENIR

OWASP aide à rendre concrètes les mesures ISO sur le développement sécurisé.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 117 — Cloud : responsabilité partagée

Cette diapositive sert à installer la notion « Cloud : responsabilité partagée ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

Faire comparer les deux colonnes : la première montre un point de vue, la seconde montre le complément ou la bonne pratique attendue. L'intérêt est de faire verbaliser les

différences, pas seulement de les lire.

- Côté gauche : Sécurité physique datacenter, Infrastructure de base, Certaines couches réseau / hyperviseur, Disponibilité selon contrat
- Côté droit : Identités, accès, clés et configurations, Données, classification, chiffrement, Architecture, journaux, supervision, Conformité métier et paramétrage

POINT DE VIGILANCE

La plupart des incidents cloud viennent de mauvaises configurations côté client.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 118 — PCA, PRA, RTO, RPO

Cette diapositive sert à installer la notion « PCA, PRA, RTO, RPO ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- PCA : Plan de continuité : continuer l'activité malgré la crise
- PRA : Plan de reprise : restaurer le SI après interruption
- RTO : Durée maximale acceptable d'interruption
- RPO : Perte maximale de données acceptable dans le temps

EXEMPLE

RTO 4h signifie : le service doit redémarrer en moins de 4h. RPO 15 min signifie : on accepte au maximum 15 min de données perdues.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 119 — Construire une résilience réaliste

Cette diapositive sert à installer la notion « Construire une résilience réaliste ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — BIA : Identifier processus critiques et impacts d'interruption
- Étape 2 — Objectifs : Fixer RTO/RPO validés par les métiers
- Étape 3 — Architecture : Sauvegardes, redondance, modes dégradés
- Étape 4 — Procédures : Restauration, communication, priorités
- Étape 5 — Tests : Exercices réguliers et amélioration

À RETENIR

Une sauvegarde jamais testée est une hypothèse, pas une preuve.

Diapositive 120 — Indicateurs SSI

Cette diapositive sert à installer la notion « Indicateurs SSI ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Taux MFA » Couverture d'une mesure clé d'accès
- Délai patch critique » Capacité à réduire l'exposition
- MTTD / MTTR » Détection et réponse aux incidents
- Taux de revues d'accès » Maîtrise du moindre privilège
- Tests PRA réussis » Résilience prouvée
- Non-conformités ouvertes » Dette de conformité et de risque

POINT DE VIGILANCE

Un indicateur doit guider une décision. S'il ne déclenche aucune action, il est décoratif.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 121 — TD — Exercice de crise ransomware

Cette diapositive sert à installer la notion « TD — Exercice de crise ransomware ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

INTERACTION — À FAIRE

Lancer l'activité en reformulant la consigne, puis laisser les étudiants produire avant de corriger. L'enseignant circule pour repérer les confusions.

- Définir les 5 premières décisions en 30 minutes
- Identifier les rôles à mobiliser
- Lister les preuves à préserver
- Préparer un message interne aux collaborateurs
- Définir les critères de retour à la normale

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 122 — L'essentiel du module 9

Cette diapositive clôt le module. L'enseignant la lit lentement et relie chaque phrase à un exemple vu pendant les quatre heures.

À RETENIR

La sécurité opérationnelle donne vie au SMSI : détecter, répondre, développer plus sûr, maîtriser le cloud et tester la continuité. Les indicateurs ferment la boucle d'amélioration.

TRANSITION

On peut maintenant passer au module suivant, qui réutilisera ce socle dans un contexte plus appliqué.

MODULE 10 — ÉTUDE DE CAS FIL ROUGE ET PRÉPARATION À L'EXAMEN · Synthétiser le cours en construisant le mini-SMSI d'une organisation fictive

Diapositive 123 — Étude de cas fil rouge et préparation à l'examen

Nous ouvrons le module 10 : Étude de cas fil rouge et préparation à l'examen. Ce module représente environ quatre heures de cours et de travaux dirigés.

OBJECTIF

Le but est de transformer les notions du module en décisions concrètes : quoi documenter, quoi justifier, quoi vérifier.

Diapositive 124 — Objectifs du module 10

Présenter les objectifs comme une feuille de route. Les étudiants doivent comprendre que chaque objectif correspond à une compétence réutilisable dans l'étude de cas fil rouge.

- Appliquer l'ensemble du cours à une organisation fictive
- Produire un périmètre, un registre de risques et une SoA simplifiée
- Justifier des mesures de sécurité selon ISO 27002 et NIST CSF
- Préparer un mini-dossier d'audit
- Réviser efficacement les notions attendues à l'examen

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 125 — Organisation fictive : EduSanté Services

Cette diapositive sert à installer la notion « Organisation fictive : EduSanté Services ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Activité : Plateforme SaaS de gestion de stages en santé
- Données : Étudiants, conventions, évaluations, données de santé incidentes
- Clients : Universités, hôpitaux partenaires, écoles privées
- SI : Application web cloud, SSO, base PostgreSQL, prestataire infogérance

À RETENIR

Le cas est volontairement réaliste : données sensibles, cloud, fournisseurs, exigences clients.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 126 — Livrable 1 — Périmètre SMSI

Cette diapositive sert à installer la notion « Livrable 1 — Périmètre SMSI ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Inclure : Plateforme SaaS, production cloud, support client, processus sécurité
- Étape 2 — Interfaces : SSO universités, hôpitaux, prestataire infogérance
- Étape 3 — Exclure : Systèmes internes hors support si justification claire
- Étape 4 — Parties intéressées : Clients, étudiants, CNIL, hébergeur, direction
- Étape 5 — Phrase de périmètre : Formulation courte et audit-able

À RETENIR

Le périmètre doit être assez clair pour qu'un auditeur sache quoi vérifier.

Diapositive 127 — Livrable 2 — Valeurs métier et DICP

Cette diapositive sert à installer la notion « Livrable 2 — Valeurs métier et DICP ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Dossiers de stage » Confidentialité + intégrité
- Disponibilité de la plateforme » Disponibilité
- Identités et rôles » Intégrité + preuve
- Conventions signées » Intégrité + preuve
- Historique d'accès » Preuve + confidentialité

À RETENIR

Un même actif peut porter plusieurs critères ; justifier la priorité est important.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 128 — Livrable 3 — Registre de risques simplifié

Cette diapositive sert à installer la notion « Livrable 3 — Registre de risques simplifié ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Phishing administrateur » accès base » MFA fort, PAM, sensibilisation, logs

- Mauvaise configuration cloud » fuite » Revue IaC, durcissement, scan CSPM
- Ransomware prestataire » interruption » Clauses, sauvegardes, PRA, segmentation
- Erreur développeur » vulnérabilité web » SAST, revue code, OWASP ASVS
- Demande RGPD mal traitée » Procédure droits, registre, rôle DPO

POINT DE VIGILANCE

Le registre doit être priorisé : cinq risques bien argumentés valent mieux que trente lignes vagues.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 129 — Livrable 4 — Scénario EBIOS

Cette diapositive sert à installer la notion « Livrable 4 — Scénario EBIOS ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — SR/OV : Cybercriminel veut monétiser les données ou rançonner
- Étape 2 — Stratégique : Passe par un prestataire infogérance moins mature
- Étape 3 — Opérationnel : Vol VPN » mouvement latéral » exfiltration » chiffrement
- Étape 4 — Gravité : Indisponibilité plateforme + notification RGPD + perte de confiance
- Étape 5 — Mesures : PAM, segmentation, EDR, sauvegardes testées, clauses fournisseur

À RETENIR

Le scénario doit raconter une histoire plausible que la direction comprend.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 130 — Livrable 5 — Mini-SoA

Cette diapositive sert à installer la notion « Livrable 5 — Mini-SoA ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- A.5.23 Cloud services » Plateforme SaaS hébergée en cloud
- A.5.19 Suppliers » Prestataire infogérance critique
- A.8.2 Privileged access » Comptes admin à fort impact
- A.8.15 Logging » Détection et preuve des accès
- A.8.28 Secure coding » Risque applicatif web
- A.5.30 ICT readiness » Objectifs de continuité clients

À RETENIR

Chaque inclusion doit être reliée à un risque ou une exigence ; chaque exclusion doit être défendable.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 131 — Livrable 6 — Pack documentaire minimal

Cette diapositive sert à installer la notion « Livrable 6 — Pack documentaire minimal ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Politique SSI : Engagements, périmètre, objectifs, responsabilités
- Procédure accès : Joiner/mover/leaver, MFA, revues
- Procédure incident : Détection, escalade, communication, preuve
- Procédure sauvegarde : RPO/RTO, tests, restauration, responsabilités

À RETENIR

Un pack minimal bien tenu vaut mieux qu'une bibliothèque documentaire jamais appliquée.

Diapositive 132 — Livrable 7 — Préparer l'audit

Cette diapositive sert à installer la notion « Livrable 7 — Préparer l'audit ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Étape 1 — Critères : Choisir clauses ISO 27001 et mesures Annex A à démontrer
- Étape 2 — Preuves : Rassembler politiques, tickets, logs, rapports, comptes rendus
- Étape 3 — Entretiens : Préparer direction, RSSI, DevOps, support, DPO
- Étape 4 — Échantillons : Comptes utilisateurs, incidents, changements, sauvegardes
- Étape 5 — Plan d'action : Identifier écarts avant l'auditeur externe

À RETENIR

La préparation d'audit doit vérifier la réalité opérationnelle, pas seulement le dossier documentaire.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 133 — Checklist de révision

Cette diapositive sert à installer la notion « Checklist de révision ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Définir DICP et donner un exemple
- Distinguer menace, vulnérabilité, risque
- Expliquer norme / méthode / règlement
- Citer les clauses ISO 27001:2022
- Expliquer SoA et registre de risques
- Présenter les 4 thèmes ISO 27002
- Dérouler les 5 ateliers EBIOS RM
- Présenter les 6 fonctions NIST CSF 2.0
- Donner les principes RGPD, NIS2, DORA
- Décrire audit, preuves, non-conformités
- Expliquer PCA/PRA/RTO/RPO
- Justifier une mesure par un risque

À RETENIR

Savoir réciter ne suffit pas : l'examen demandera d'appliquer les notions à un cas.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 134 — Structure indicative de l'examen

Cette diapositive sert à installer la notion « Structure indicative de l'examen ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- Questions courtes » Définitions : DICP, SMSI, SoA, RTO, NIS2...
- Analyse de cas » Identifier actifs, risques, impacts, mesures
- Mini-audit » Associer exigence, preuve, non-conformité
- Question de synthèse » Comparer ISO 27001, ISO 27002, NIST CSF, EBIOS

À RETENIR

La meilleure préparation est de refaire les TD et de savoir justifier ses choix.

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 135 — Ressources fiables

Cette diapositive sert à installer la notion « Ressources fiables ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

- ISO/IEC : Famille 27000, 27001, 27002, 27005
- ANSSI : Guides d'hygiène, EBIOS RM, recommandations cloud
- NIST : CSF 2.0, SP 800-53, SP 800-61, SP 800-218
- CNIL / ENISA : RGPD, guides pratiques, cybersécurité européenne

À RETENIR

Un bon professionnel cite ses sources et vérifie les versions des référentiels.

Diapositive 136 — Projet final — Soutenance courte

Cette diapositive sert à installer la notion « Projet final — Soutenance courte ». L'idée est de partir du sens courant des mots, puis de les relier progressivement à un usage professionnel.

INTERACTION — À FAIRE

Lancer l'activité en reformulant la consigne, puis laisser les étudiants produire avant de corriger. L'enseignant circule pour repérer les confusions.

- Présenter périmètre, valeurs métier et 5 risques prioritaires
- Expliquer un scénario EBIOS en langage direction
- Justifier 8 mesures ISO 27002 dans une mini-SoA
- Montrer 4 preuves attendues en audit
- Conclure par 3 priorités d'amélioration

À RETENIR

À retenir : la notion doit toujours être reliée à un risque réel, à une décision de gouvernance ou à une preuve attendue lors d'un audit.

Diapositive 137 — L'essentiel du module 10

Cette diapositive clôt le module. L'enseignant la lit lentement et relie chaque phrase à un exemple vu pendant les quatre heures.

À RETENIR

Le module 10 assemble tout : gouvernance, risque, mesures, droit, audit et opérations. La compétence centrale est de justifier une décision de sécurité de façon claire, traçable et proportionnée.

TRANSITION

On peut maintenant passer au module suivant, qui réutilisera ce socle dans un contexte plus appliqué.

CLÔTURE DU COURS

Diapositive 138 — Merci de votre attention

Le cours est terminé. Remercier les étudiants, rappeler que les normes ne sont pas une fin en soi mais un langage commun pour maîtriser les risques, puis ouvrir les questions.

À RETENIR

Conclusion : être professionnel en sécurité, c'est savoir justifier des choix proportionnés, documentés et vérifiables.